

[Skip to main content](#)

Please enable JavaScript in your web browser to get the best experience.



[Home](#)

Utility navigation

- [About NCSC](#)
- [Report an incident](#)
- [Contact us](#)

Open Search

Menu

Main navigation

- Advice & guidance
Back

Advice & guidance

Our advice & guidance covers a broad range of topics

- **Find information for...**

- [You & your family](#)
- [Small & medium sized organisations](#)
- [Large organisations](#)
- [Self employed & sole traders](#)
- [Public sector](#)
- [Cyber security professionals](#)
- [All advice and guidance articles](#)

- **Popular topics**

- [Artificial intelligence](#)
- [Cyber attack](#)
- [Frontier AI](#)
- [Passkeys](#)
- [Phishing](#)
- [All topics](#)

- **Other resources**

- [Glossary of terms](#)
- [Infographics](#)
- [Verify an NCSC contact](#)
- [Heightened cyber threat information](#)
- [Cyber Governance for Boards](#)

- Respond to a cyber attack
Back

Respond to a cyber attack

Resources for individuals and organisations in the UK who have experienced an online scam or cyber attack.

- **Find advice for...**
 - [Advice for medium to large organisations](#)
 - [Advice for sole traders and small businesses](#)
 - [Advice for individuals](#)
 - **Respond to...**
 - [Hacked account](#)
 - [Infected device](#)
 - [Ransomware attack](#)
 - [Suspicious messages](#)
 - Find a product or service
- Back

Find a product or service

Find a range of products & services from NCSC and certified 3rd party suppliers

- **In this section**
 - [Products & services overview](#)
 - [Browse cyber security services](#)
 - [NCSC assured services](#)
 - [Assuring technology](#)
 - [Search assured providers](#)
 - [Cyber Essentials](#)
 - **Useful links**
 - [Active Cyber Defence services](#)
 - [MyNCSC](#)
 - Education & skills
- Back

Education & skills

Working with industry, government and academia to support the next generation of researchers, students and cyber security professionals

- **Find information for...**
 - [Schools](#)
 - [Higher education](#)
 - [Professional skills training](#)
 - [Working with the NCSC](#)
 - [Research & academia](#)
 - **Education & academia resources**
 - [CyberFirst](#)
 - [CyberSprinters \(7-11 year olds\)](#)
 - [CyberFirst Navigators \(11-14 year olds\)](#)
 - [Training resources for school staff](#)
 - [Resources for higher education institutions](#)
 - [Cyber Security Body of Knowledge \(CyBOK\)](#)
 - **Industry & skill resources**
 - [CYBERUK 2026](#)

- [NCSC for StartUps](#)
- [Industry 100](#)
- [Cyber League](#)
- News
- Back

News

All the latest information to help you keep track of what's happening

- **In this section**

- [News](#)
- [Blogs](#)
- [Speeches](#)
- [Reports & advisories](#)
- [Malware analysis reports](#)
- [CYBERUK 2026](#)

- **Stay up to date**

- [The NCSC's Cyber Series podcast](#)
- [Subscribe](#)
- [About NCSC](#)
- [Report an incident](#)
- [Contact us](#)

Close Search

Search

Popular Searches

- [Passkeys](#)
- [Training](#)
- [Cyber Essentials](#)
- [AI](#)
- [Phishing](#)
- [Cyber Assessment Framework](#)

Guidance

Password administration for system owners

Password strategies that can help your organisation remain secure.

Pages

- [Password administration for system owners](#)
 - [Password policy: updating your approach](#)
 - [Password manager buyers guide](#)

Password policy: updating your approach

Advice for system owners responsible for determining password policies and identity management within their organisations.

Password policy: contains advice for system owners responsible for determining password policy. It may be useful also for anyone developing or maintaining these services used by organisations.

The NCSC is working to reduce organisations' reliance on their users having to recall large numbers of complex passwords. This guidance advocates a greater reliance on **technical defences** and **organisational processes**, with passwords forming just **one part** of your wider access control and identity management approach.

More specifically, this guidance will help you to:

- understand the benefits and limitations of passwords
- examine and (if necessary) challenge existing corporate password policies, and help update to a modern approach
- understand the decisions to be made when determining password policy
- learn how technical measures can reduce the password burden on your users
- implement password policies which support the ways in which people naturally work
- help users to create and manage passwords that are harder to guess

As a system owner, you may not be directly responsible for the authentication methods within third party services your organisation uses. In these cases, this guidance can help you to understand the risks and benefits when selecting such services, and inform your selection of one that best meets your business and security needs.

Introduction: the problems with passwords

Bill Gates [predicted the death of the password](#) around 15 years ago. Many assumed that alternative authentication methods would be adopted to control access to IT infrastructure, data, and services. In fact, password use has risen, and they remain the default method of authentication for a huge range of services, both at work and home.

This increase in password use is mostly due to the surge of online services, including those provided by government and the wider public sector, and the massive growth in use of personal computers, smartphones and tablets. Passwords are often seen as an easily-implemented, low-cost security measure as they do not require special hardware, with obvious attractions for managers within enterprise systems.

However, this proliferation of password use, and increasingly complex password requirements, places an unrealistic demand on users. Inevitably, users will devise their own coping mechanisms to cope with 'password overload'. This includes re-using the same password across different systems, using simple and predictable password creation strategies, or writing passwords down where they can be easily found. Attackers exploit these well-known coping strategies, leaving your staff and organisation vulnerable.

How are passwords discovered?

Attackers use a variety of techniques to discover passwords, exploiting a range of social and technical vulnerabilities. These include:

- tricking someone into revealing their password via social engineering (including phishing and coercion)
- using the passwords leaked from data breaches to attack other systems where users have used the

same password

- password spraying (using a small number of commonly-used passwords in an attempt to access a large number of accounts)
- brute-force attacks (the automated guessing of large numbers of passwords until the correct one is found)
- theft of a password hash file, where the hash can be broken to recover the original passwords
- 'shoulder surfing' (observing someone typing in their password)
- finding passwords which have been stored insecurely, such as sticky notes kept close to a device, or documents stored on devices
- manual password guessing (perhaps using personal information 'cribs' such as name, date of birth, or pet names)
- intercepting a password (or password hash) as it is transmitted over a network
- installing a keylogger to intercept passwords when they are entered into a device

These techniques are widely available and documented on the internet, and many use automated tools requiring only moderate technical skills.

Passwords can only do so much

Passwords have a limited ability to protect your data and systems. Even when implemented correctly, passwords are limited in helping prevent unauthorised access. If an attacker discovers or guesses the password, they are able to impersonate a user. Less obviously, every new password has an associated burden on the person using it.

Having said this, there's lots you can do to make sure your password policy is as effective as possible and integrated as part of your wider organisational approach to authentication. The six tips are:

- Tip 1: [Reduce your organisation's reliance on passwords](#)
 - Tip 2: [Implement technical solutions](#)
 - Tip 3: [Protect all passwords](#)
 - Tip 4: [Help users cope with password overload](#)
 - Tip 5: [Help users to generate better passwords](#)
 - Tip 6: [Use training to support key messages](#)
-

Tip 1: Reduce your organisation's reliance on passwords

There are circumstances where a password is still an appropriate solution, for example access to a guest Wi-Fi network. However, passwords have been overused and applied in many areas where they are not appropriate. A good way to minimise password burden is to only implement passwords when they are really needed and suitable.

Technical solutions (such as single sign-on) can also reduce the burden on staff. While these may incur some additional setup and operating costs, they are easy to use and improve the whole system security, so can provide good value for money in the longer term. Many devices already come with biometric login options that could be configured to use instead.

Use multi-factor authentication (MFA) for important accounts

One of the most effective ways of providing additional protection to a password protected account is to use MFA. Accounts that have been set up to use MFA require a second factor, which is something that you (and **only** you) can access. This could be a code that's sent to you by text message, or that's created by an app, so even if an attacker discovers a password, they won't be able to access the associated account without also compromising the other factor. MFA is best used where there may be additional risk (such as logging into an account on a new device, internet facing systems or for priority accounts). For more

detailed information, refer to the [NCSC's guidance on Multi-factor authentication for online services](#).

Use single sign-on systems

Single sign-on (SSO) allows staff to use just one set of credentials to automatically gain access to multiple applications and services. So a user might log into their work machine and have access to everything they need, without having to enter another set of credentials.

SSO may take the form of a web-based portal that authenticates a user across all their cloud services. This massively reduces the pressure on a user to create and remember good passwords. However, if an attacker compromises a user's account or password, that attacker could have easy access to far more content than they might have in a traditional system. For this reason, we recommend that SSO be implemented to require MFA.

In summary:

- Only use passwords where they are needed and appropriate
 - Consider alternatives to passwords such as SSO, hardware tokens and biometric solutions.
 - Use MFA where possible for all important accounts and internet facing systems.
-

Tip 2: Implement technical solutions

Your system's security should always rely on effective technical defences rather than depending on unachievable user behaviour. This section outlines the technical solutions your organisation should either implement directly (or look to see evidence of when acquiring third party services).

Use throttling or account lockout

Password systems can be configured so that there is a progressively increasing time delay between successive login attempts - a technique known as 'throttling'. This restricts the number of guesses an attacker can attempt while giving users multiple opportunities to remember their password. An alternative is account lockout, where a user only has a fixed number of attempts to enter their password before their account is locked.

- Throttling is preferred, because account lockout can leave legitimate users unable to access their accounts, and requires access to an account recovery method.
- Account lockout can provide an attacker with an easy way to launch a denial of service attack, particularly for large online systems.
- If using account lockout, we recommend you allow between 5 and 10 login attempts before the account is frozen, to avoid accidental lockout.

Security monitoring

There are additional methods for detecting and preventing the misuse of accounts that can be considered **alongside** account throttling (or lockout). For example, you can use security monitoring to detect and alert you to what may be indicators of malicious or abnormal behaviour, such as:

- login attempts that fail the second step of MFA
- brute-forcing of account passwords, including password spraying
- login attempts from unexpected geographical areas
- reports of unexpected account lockouts or other unusual account behaviour from users

Password deny lists

If users are choosing their own passwords, a helpful defence is to employ a password deny list that prevents the most common (and therefore easily guessed) passwords being used. If you can't deny list passwords at the point when they are created, you might be able to retroactively search your password database for the hashes of deny listed passwords. If high numbers of common passwords are found, this is a sign that you should offer users further support managing and choosing their passwords. See Tips 4, 5 and 6 for further information.

A deny list can be created from a published lists of common passwords or can be tailored to your organisation.

In summary:

- Use account lockout or throttling to defend against brute force attacks.
 - If using lockout, allow users between 5 and 10 login attempts before locking out accounts.
 - Consider using security monitoring to defend against brute force attacks.
 - Password blacklisting prevents common, guessable passwords being used.
-

Tip 3: Protect all passwords

Passwords need to be protected within your system, even if the information on the protected system is relatively unimportant. Reuse of passwords means that an attacker can use this information to attempt to access more important accounts, where further damage can be done.

This section gives advice for system developers and engineers, and will help security practitioners to select those third party products and systems that provide more secure methods of password storage and processing.

Protect passwords in transit

Passwords can be intercepted when in transit. To protect them you should ensure that all corporate web apps requiring authentication use HTTPS. A common type of attack involves stealing a security token to gain access to another device or server. [‘Pass the hash’](#) is an example of this, where a stolen hash is used to authenticate the attacker. For more information, refer to the [NCSC guidance on preventing lateral movement](#).

Protect the access management system

The access management system needs to be protected to prevent attackers using it to gain access to your system (for example by modifying password policies, or stealing tokens), whether this is within your own organisation or a cloud or other online service. While you can't influence the defences of the third party systems, you should take steps to protect the access management systems you manage internally, and you should find out how third party suppliers do the same. For some further information, please refer to the [NCSC guidance on identity and access management](#).

Protect passwords at rest

Make sure the systems you deploy do not store passwords as plain text, even if the information on the protected system is relatively unimportant. Periodically search systems for password information that is stored in plain text.

All passwords should be stored in a hashed format, using multiple iterations of the hash function. Hashing is a one-way cryptographic function which converts a plain text password into a 'hash', an unreadable

string of characters designed to be impossible to convert back. However, attackers can still use brute-force attacks and rainbow tables (pre-computed tables for reversing cryptographic hash functions) to retrieve passwords from stolen hashes. For this reason, applications should add a ‘salt’ to a password before hashing. The hash function should follow public standards (such as [PBKDF2](#)), for example [SHA-256](#).

An attacker who has accessed a password hash file will not know the actual passwords. But if the passwords have been hashed poorly, or the attacker has enough computing power, it may be possible for them to recover some of the passwords. For this reason it is important to protect access to the user database. As well as being a target for attackers looking to compromise your system, these are a target in their own right, even if the information is out of date.

Prioritise securing important or vulnerable accounts

While all passwords should be protected, accounts that have highly privileged access to systems, services and data (or accounts that are accessible externally such as cloud services or remote access) are especially attractive to attackers. MFA should be the primary method for protecting these accounts. Imposing additional password complexity requirements on such accounts will increase the burden on these users, but may not provide any more protection.

Highly privileged accounts should **not** be used for high risk or day-to-day user activities, such as accessing external email or browsing the internet. For these and other normal business use activities, administrators should also have standard user accounts (with different passwords).

Administrator accounts for infrastructure devices may have pre-set passwords that can be easily found out. For this reason, all default vendor-supplied passwords that come with any system, software or device should be changed before deployment. Vendors can help here by documenting all default passwords and describing how to change them.

In summary

- Ensure that all corporate web apps requiring authentication use HTTPS.
- Protect any access management systems you manage.
- Choose services and products that protect passwords using multiple iterations of a salted cryptographic hash function.
- Protect access to user databases.
- Prioritise privileged and vulnerable accounts such as administrators, cloud accounts and remote users.
- Change all default passwords.

Tip 4: Help users cope with password overload

Users have traditionally been told to remember passwords, and to not share them, re-use them, or write them down. The problem with this is that the typical user has dozens of passwords to remember – not just yours. To cope with this overload, users resort to workarounds, such as reusing passwords, insecure storage or predictable passwords. This section explains how your organisation can provide **sanctioned mechanisms** to help users manage passwords, so there's less incentive to adopt insecure workarounds.

Use password management software or other secure storage

You should provide appropriate facilities to store passwords. The NCSC recommend the use of password managers for secure storage wherever appropriate. As well as providing secure storage, password managers can help users by generating and auto-filling passwords when required. We recommend that all online services permit the use of password managers, and that users should be [allowed to paste passwords](#)

[into web forms](#). However, like any piece of security software, password managers are not impregnable and are an attractive target for attackers. For more information, refer to the [NCSC Password Manager Buyers Guide](#).

If a password manager is not suitable you should provide physical storage for recorded passwords such as a secure cabinet. You may also need secure storage for MFA tokens. This should be separate from the stored password.

Don't enforce regular password expiry

Regular password changing harms rather than improves security. Many systems will force users to change their password at regular intervals, typically every 30, 60 or 90 days. This imposes burdens on the user and there are costs associated with recovering accounts.

Forcing password expiry carries no real benefits because:

- the user is likely to choose new passwords that are only minor variations of the old
- stolen passwords are generally exploited immediately
- resetting the password gives you no information about whether a compromise has occurred
- an attacker with access to the account will probably also receive the request to reset the password
- if compromised via insecure storage, the attacker will be able to find the new password in the same place

Instead of forcing expiry, you should counter the illicit use of compromised passwords by:

- ensuring an effective movers/leavers process is in place
- automatically locking out inactive accounts
- monitoring logins for suspicious behaviour (such as unusual login times, logins using new devices)
- encouraging users to report when something is suspicious

You can also mitigate the risk of compromised accounts by using MFA, which will make a compromised password less useful to an attacker. Some MFA methods (such as SMS or email notifications) can even warn the user that they have been compromised, as they will receive a code when they did not request it. If you are using this form of MFA, you should encourage users to report this behaviour through your training.

Note: Users **must** change their passwords when you **know (or suspect)** it has been compromised.

Managing shared access

Sharing work accounts, or even occasional use by anyone other than the account holder, introduces a number of risks. As well as the possibility of users gaining access to unauthorised resources, sharing accounts negates the benefit of authenticating a specific user. In particular, the ability to audit and monitor a specific user's actions is lost, an essential forensic requirement for some accounts.

If passwords are being shared, try and find alternative solutions that support the business need for sharing. For example, many accounts will have a way to **delegate** privileges to another account (such as access to a document or inbox). Delegation should be used instead of sharing accounts wherever possible.

If alternatives are not possible, and there remains a strong business need for shared access to an account or device, then access to the password should be monitored and continually reviewed to manage the risk:

- the password should only be shared within the smallest possible group of known and trusted users
- the password should not be exposed to users who do not have permission to access it

- if someone is no longer allowed access, the password should be changed

Some password managers allow users to share passwords in a more secure way (for example, they can audit access to the password and automatically sync password changes). If you have a business need to share a password, then consider using a password manager to do this.

In summary

- Users have a whole suite of passwords to manage, not just yours.
 - Allow users to securely store their passwords.
 - Only ask users to change their passwords on indication or suspicion of compromise.
 - Use delegation tools instead of password sharing.
 - Where there's a pressing business requirement to share passwords, use additional controls to provide the required oversight.
-

Tip 5: Help users to generate better passwords

Passwords can be created by the user themselves, or they can be supplied to them by a service. Both methods have advantages and disadvantages which you will need to consider when choosing a method. Either way, if you are depending only on the strength of your passwords (either machine or user generated) then your system will remain exposed to many attacks.

You should use the additional defences discussed above to provide the majority of your protection against a range of attacks.

Implementing machine-generated passwords

Machine-generated passwords eliminate those passwords that would be simple for an attacker to guess. They require little effort from the user to create, and can produce passwords that are random and unique. However, most machine-generated passwords are very difficult for people to remember. For this reason, the NCSC recommend that they should be used with a password manager. Most password managers include a random password generator, and staff should be encouraged to use this wherever possible.

Since machine-generated passwords are difficult for people to remember, using them **without** a password manager increases:

- the costs involved in providing account recovery for forgotten passwords
- the likelihood of users adopting insecure workarounds

Ideally, if using a machine-generated password without a password manager, the system should give users a choice of passwords (so they can select the one they find the most memorable), or produce CVC-CVC (consonant-vowel-consonant) style passwords that are easier to remember. However, you should assume that an attacker could learn the format you use, and will adjust their attack accordingly.

Working with user-generated passwords

User-generated passwords are quick and easy to implement, and are the most common way of composing passwords. However, they carry risks that machine-generated passwords do not:

- users may re-use passwords that they already use on other systems
- users may use easily guessed passwords (such as a pet's name)
- users may adopt predictable password generation strategies (such as replacing the letter 'o' with a zero)

This means that systems with user-generated passwords will normally contain a large number of weak passwords that will quickly fall to an automated guessing attack. Password deny listing can help to prevent the most common passwords being used.

Password strength meters aim to help users assess the strength of their self-generated passwords. They may steer users away from the weakest passwords, but often fail to account for the factors that can lead to guessable passwords (such as using personal information, or repeating characters or common character strings). You should be aware of these limitations if using password strength meters.

Do not use complexity requirements

Using complexity requirements (that is, where staff can only use passwords that are suitably complex) is a poor defence against guessing attacks. It places an extra burden on users, many of whom will use predictable patterns (such as replacing the letter 'o' with a zero) to meet the required 'complexity' criteria. Attackers are familiar with these strategies and use this knowledge to optimise their attacks. Additionally, complexity requirements provide no defence against common attack types such as social engineering or insecure storage of passwords.

For the above reasons, the NCSC do **not** recommend the use of complexity requirements when implementing user generated passwords. The use of technical controls to defend against automated guessing attacks is far more effective than relying on users to generate (and remember) complex passwords. However, you should specify a minimum password length, to prevent very short passwords from being used. Avoid using any maximum length requirements that a user might try to exceed, as they will make it harder for users to choose a suitable password that fits the length criteria. Password length should only be capped by the capabilities of your system. Be aware that enforcing excessively long passwords will introduce other burdens (such as time taken to enter passwords, and the increased likelihood of mistyping especially on touch screen devices). Adopting the '[three random words](#)' technique can help users to use suitably complex passphrases that they can actually remember.

In summary

- Be aware of the pros and cons of different password generation methods.
 - If password managers are used, encourage the use of the built-in password generator.
 - Complexity requirements provide no defence against common attacks and should not be used.
 - Prevent users setting passwords that are too short.
 - Don't impose artificial capping on password length.
-

Tip 6: Key messages for training

Your existing training may consist of giving users a straightforward lists of 'dos and don'ts'. This sounds sensible enough, but it can be counterproductive as your advice may contradict what they've heard elsewhere, and could cause confusion. Instead, your training should focus on the things that will actually improve security. These include:

- highlighting the risks involved in using the same passwords across home and work accounts
- helping users to create passwords that can't be easily guessed; training can emphasise the importance of avoiding personal information (such as names, dates, and sports teams)
- using the three random words technique to help users create less predictable passwords
- training staff how to use password managers (if you're using them), including features such as the password generator

Helping users to manage the password burden

There are a number of ways you can help your staff to manage their passwords:

- permit techniques that are low risk (for example, secure storage or remaining logged in)
- provide **tailored** guidance that's easy for users to find and put into action
- ensure users understand which of their accounts are of higher priority
- provide users with the tools or training they need to protect these priority accounts (for example MFA, ensuring staff have logged out)

Helping users manage passwords at home

You may want to consider providing extra guidance to help users manage their passwords at home. This will help them manage their full portfolio of passwords covering both work and personal accounts, and reduce their overall password burden. The NCSC recommend the following guidance to help users manage their passwords for home accounts:

- [Cyber Aware: Password Guidance](#)
- [NCSC Guidance: Setting up two-factor authentication](#)
- [NCSC Blog: Living with password re-use](#)

In summary

- Emphasise the risks of re-using passwords across work and home accounts.
- Help users to choose passwords that are difficult to guess.
- Help users to prioritise their high value accounts.
- Consider making your training applicable to their personal lives.

[Previous page:](#)

[Password administration for system owners](#) [Next page:](#)

[Password manager buyers guide](#)

Reviewed

19 November 2018

Version

1.0

Written for

Written for

[Large organisations](#) [Public sector](#) [Cyber security professionals](#)

Share and print this article

Share

Share

Close share options

[Share onFacebook](#)

[Share onLinkedIn](#)

[Share onX](#)

Copy Link

Was this article helpful?

- [Yes the article was helpful](#)
- [No the article was not helpful](#)

Close Feedback Form

Back to top

Share

Close share options

[Share on Facebook](#)

[Share on LinkedIn](#)

[Share on X](#)

Copy Link

[Home](#)

Follow us

- [X](#)
- [LinkedIn](#)
- [Instagram](#)
- [Threads](#)
- [RSS](#)

About this website

- [Privacy notice](#)
- [Cookies](#)
- [Accessibility](#)
- [Terms & conditions](#)
- [Social media policy](#)

Contact the NCSC

- [Report an incident](#)
- [Report suspicious messages or websites](#)
- [Verify an NCSC contact](#)
- [Report a vulnerability](#)
- [Contact the press office](#)
- [Can't find what you're looking for?](#)

Useful links

- [GCHQ](#)
- [MI5](#)
- [SIS](#)
- [NPSA](#)
- [GOV.UK](#)